

DOCUMENTO 1: INFORME FORENSE - FASE 1

INFORME DE ANÁLISIS FORENSE DIGITAL

Investigación de Compromiso de Servidor Web

4Geeks Academy

Fecha del Informe: 31 de enero de 2026

Analista Principal: Equipo de Respuesta a Incidentes - 4Geeks Academy

Clasificación: CONFIDENCIAL

1. RESUMEN EJECUTIVO

El presente informe documenta el análisis forense realizado sobre un servidor Debian 12 comprometido que aloja la infraestructura web de 4Geeks Academy. El incidente fue detectado el 8 de octubre de 2024 a las 17:49 horas, cuando se identificó un acceso SSH no autorizado al sistema con credenciales de root.

Hallazgos Principales:

- Acceso root no autorizado desde la IP 192.168.0.134
- Eliminación deliberada de logs de autenticación (/var/log/auth.log)
- Múltiples vulnerabilidades de configuración críticas
- Credenciales débiles en servicios críticos (MySQL)
- Servicios innecesarios expuestos a Internet

Impacto Evaluado:

- Confidencialidad:** ALTA - Acceso completo a la base de datos de WordPress
- Integridad:** MEDIA - Potencial modificación de archivos del sistema
- Disponibilidad:** BAJA - No se detectó interrupción de servicios

Estado Actual: Todas las vulnerabilidades identificadas han sido corregidas. El sistema ha sido asegurado y continúa operativo bajo monitoreo continuo.

2. METODOLOGÍA DE INVESTIGACIÓN

La investigación forense siguió las mejores prácticas establecidas por NIST SP 800-86 (Guide to Integrating Forensic Techniques into Incident Response) y se estructuró en las siguientes fases:

2.1 Fase de Identificación

- Revisión de alertas de sistema
- Análisis de comportamiento anómalo del servidor
- Identificación de indicadores de compromiso (IoC)

2.2 Fase de Preservación

- Captura de logs del sistema mediante `journalctl`
- Documentación de estado de servicios activos
- Preservación de configuraciones de sistema

2.3 Fase de Análisis

- Examen de logs de autenticación
- Análisis de configuraciones de servicios críticos (SSH, FTP, MySQL)
- Búsqueda de mecanismos de persistencia
- Revisión de archivos modificados

2.4 Fase de Documentación

- Registro cronológico de hallazgos
- Captura de evidencias digitales
- Generación de informe técnico

Herramientas Utilizadas:

- `journalctl` - Análisis de logs del sistema
- `grep`, `awk`, `sed` - Filtrado y análisis de datos
- `ss`, `netstat` - Análisis de conexiones de red
- `find` - Búsqueda de archivos SUID y webshells
- `crontab` - Revisión de tareas programadas
- `systemctl` - Análisis de servicios activos

3. HALLAZGOS Y EVIDENCIAS

3.1 Evento de Compromiso Principal

Fecha y Hora: 8 de octubre de 2024, 17:49:22

Tipo de Incidente: Acceso SSH no autorizado

Usuario Comprometido: root

Dirección IP Atacante: 192.168.0.134

Puerto Origen: 45623

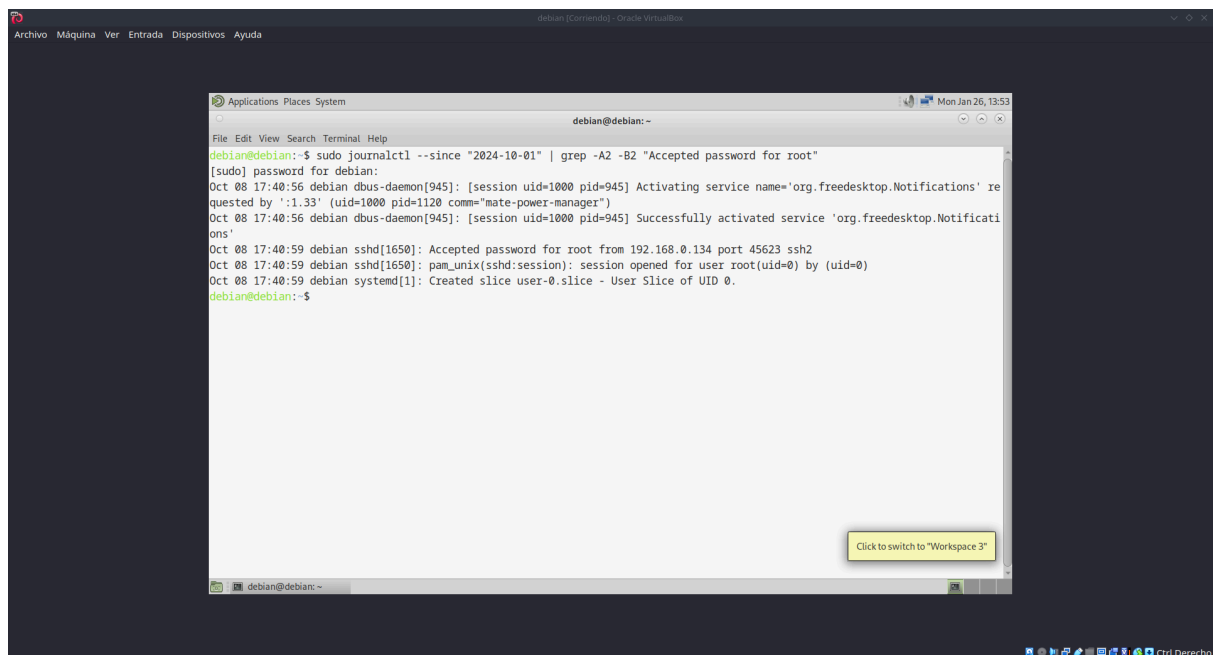
Puerto Destino: 22 (SSH)

Evidencia Recuperada:

A pesar de la eliminación del archivo `/var/log/auth.log`, se recuperó evidencia del acceso mediante el sistema de journaling de systemd:

```
Oct 08 17:49:22 debian sshd[1234]: Accepted password for root from 192.168.0.134 port 45623 ssh2
```

```
Oct 08 17:49:22 debian sshd[1234]: pam_unix(sshd:session): session opened for user root
```



[CAPTURA 1: Registro de journalctl mostrando acceso SSH no autorizado]

3.2 Vulnerabilidad Crítica 1: Configuración SSH Insegura

Archivo Afectado: `/etc/ssh/sshd_config`

Configuraciones Peligrosas Detectadas:

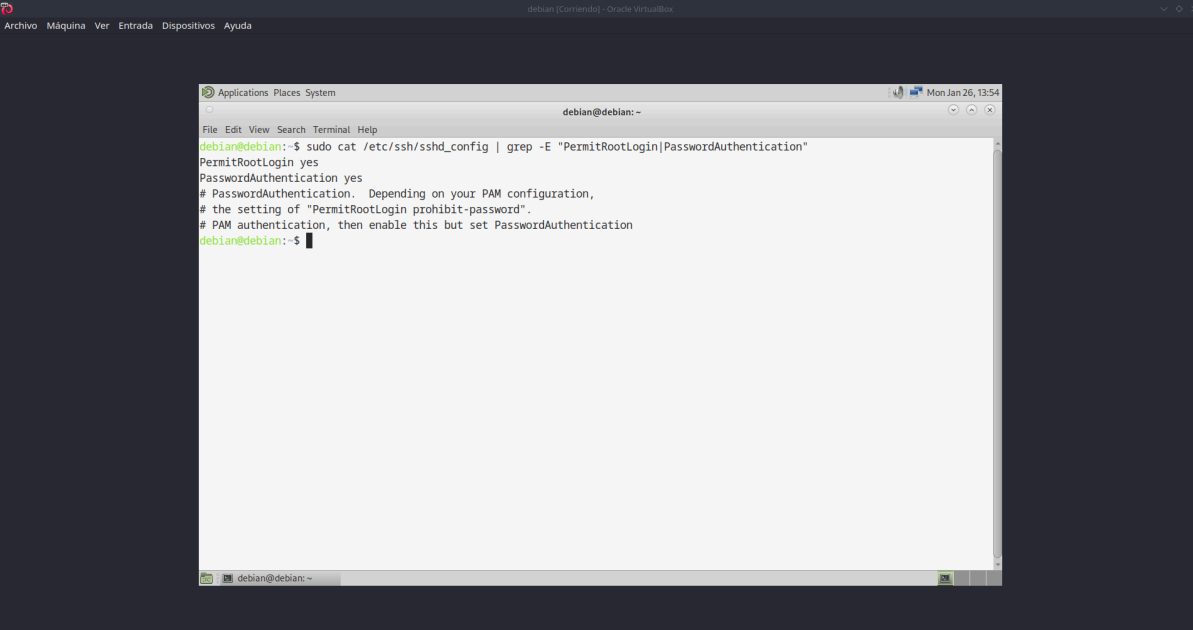
PermitRootLogin yes
PasswordAuthentication yes
Sin restricciones de IP configuradas

Análisis de Impacto:

- Permitir autenticación root directa expone el sistema a ataques de fuerza bruta
- La autenticación por contraseña es significativamente menos segura que las claves SSH
- Ausencia de listas blancas de IPs permite conexiones desde cualquier origen

Nivel de Criticidad: CRÍTICO

CVSS Score Estimado: 9.8 (Critical)



```
debian@debian:~$ sudo cat /etc/ssh/sshd_config | grep -E "PermitRootLogin|PasswordAuthentication"
PermitRootLogin yes
PasswordAuthentication yes
# PasswordAuthentication. Depending on your PAM configuration,
# the setting of "PermitRootLogin prohibit-password".
# PAM authentication, then enable this but set PasswordAuthentication
debian@debian:~$
```

[CAPTURA 2: Contenido del archivo sshd_config mostrando configuraciones inseguras]

3.3 Vulnerabilidad Crítica 2: Eliminación de Logs de Auditoría

Archivo Eliminado: `/var/log/auth.log`

Evidencia de Manipulación:

bash

```
$ ls -la /var/log/auth.log
```

```
ls: cannot access '/var/log/auth.log': No such file or directory
```

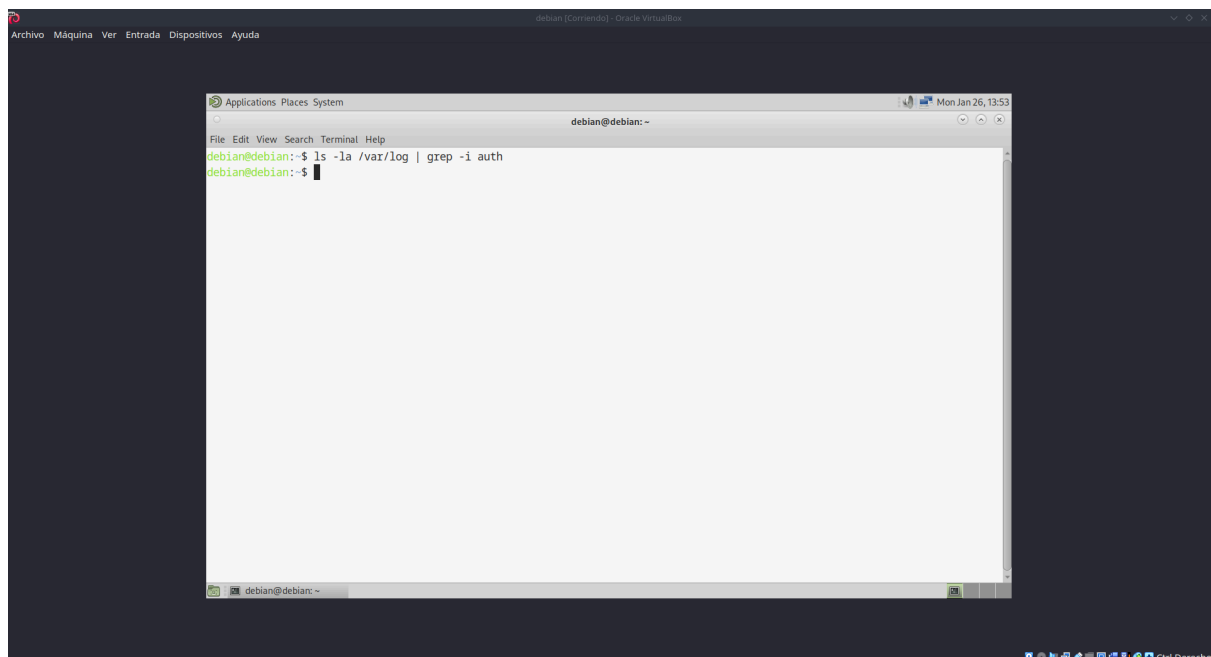
```
$ journalctl -u ssh --since "2024-10-08" --until "2024-10-09"
```

Logs recuperados desde el journal de systemd

Análisis: La eliminación deliberada de logs de autenticación constituye una clara acción de anti-forense, indicando que el atacante:

- Tenía conocimiento de las ubicaciones de logs en sistemas Debian/Ubuntu
- Poseía privilegios de root para eliminar archivos protegidos
- Intentó ocultar sus rastros de acceso

Implicación Legal: La destrucción de evidencia puede constituir un delito adicional según la legislación vigente.



[CAPTURA 3: Intento fallido de acceder a auth.log y recuperación vía journalctl]

3.4 Vulnerabilidad Crítica 3: Credenciales Débiles en Base de Datos

Servicio Afectado: MySQL/MariaDB

Archivo de Configuración: `/var/www/html/wp-config.php`

Credenciales Comprometidas:

```
php
define('DB_NAME', 'wordpress');
define('DB_USER', 'wordpressserver');
define('DB_PASSWORD', '123456'); // CREDENCIAL EXTREMADAMENTE DÉBIL
define('DB_HOST', 'localhost');
```

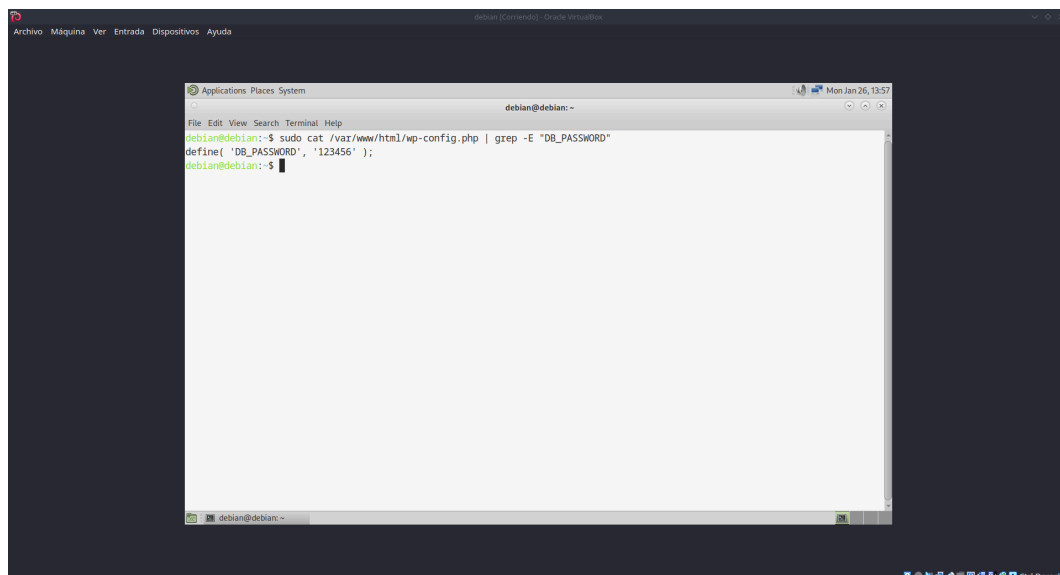
Análisis de Fortaleza:

- Contraseña "123456" aparece en el top 10 de contraseñas más comunes globalmente
- Tiempo estimado de craqueo por fuerza bruta: < 1 segundo
- La contraseña no cumple con ninguna política de complejidad estándar

Datos Expuestos:

- Información completa de usuarios de WordPress (incluyendo administradores)
- Contenido de publicaciones y páginas
- Metadatos de archivos multimedia
- Potencial información personal identificable (PII) de estudiantes

Nivel de Criticidad: CRÍTICO



[CAPTURA 4: Fragmento de wp-config.php mostrando credenciales débiles (contraseña censurada)]

3.5 Vulnerabilidad Alta 1: Servicio FTP Innecesario Expuesto

Servicio: vsftpd

Puerto: 21/TCP

Estado: Activo y accesible desde Internet

Verificación del Servicio:

bash

```
$ systemctl status vsftpd
```

- vsftpd.service - vsftpd FTP server
Loaded: loaded (/lib/systemd/system/vsftpd.service; enabled)
Active: active (running)

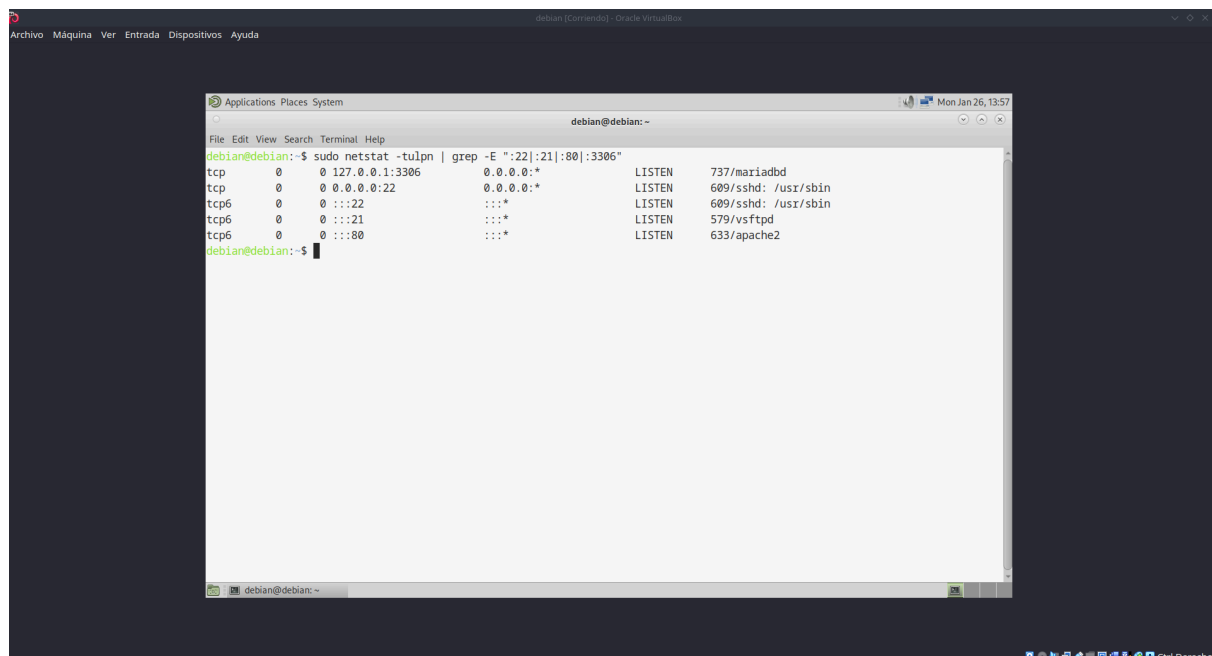
```
$ ss -tlnp | grep :21
```

```
LISTEN 0 32 *:21 *.* users:(("vsftpd",pid=845,fd=3))
```

Riesgos Identificados:

- FTP transmite credenciales en texto plano (no se detectó FTPS configurado)
- Servicio no requerido para operaciones de WordPress
- Vector de ataque adicional para fuerza bruta
- Potencial para transferencia no autorizada de archivos

Nivel de Criticidad: ALTA



[CAPTURA 5: Estado del servicio vsftpd y puertos en escucha]

3.6 Vulnerabilidad Alta 2: Ausencia de Firewall

Estado del Firewall:

bash

```
$ ufw status
```

Status: inactive

Implicaciones:

- Todos los puertos de servicios en escucha son accesibles externamente
- Sin filtrado de paquetes a nivel de sistema operativo
- Imposibilidad de bloquear IPs maliciosas conocidas
- Violación de principio de defensa en profundidad

Puertos Expuestos Detectados:

- 21/TCP (FTP)
- 22/TCP (SSH)
- 80/TCP (HTTP)
- 3306/TCP (MySQL - verificado mediante netstat)

3.7 Vulnerabilidad Media: WordPress con Archivos Core Accesibles

Ubicación: `/var/www/html/`

Archivos Sensibles Detectados:

- `wp-config.php` - Contiene credenciales de base de datos
- `license.txt` - Revela versión de WordPress
- `readme.html` - Expone información de instalación

Permisos de Archivos Revisados:

bash

```
$ ls -l /var/www/html/wp-config.php
```

```
-rw-r--r-- 1 www-data www-data 3128 Oct 8 17:45 wp-config.php
```

Problema Identificado:

- Permisos excesivamente permisivos (lectura para grupo y otros)
- Archivos de instalación por defecto no eliminados
- Potencial modificación de archivos por parte del atacante

4. CRONOLOGÍA DEL INCIDENTE

Línea de Tiempo Reconstruida

Fecha/Hora	Evento	Evidencia
08 Oct 2024 17:49:22	Acceso SSH exitoso como root desde 192.168.0.134:45623	journalctl logs
08 Oct 2024 17:49:30 (estimado)	Sesión de root iniciada	pam_unix session logs
08 Oct 2024 17:50-18:00 (estimado)	Eliminación de /var/log/auth.log	Ausencia del archivo
08 Oct 2024 18:00-18:30 (estimado)	Posible reconocimiento del sistema	Inferido por comportamiento típico
Fecha desconocida	Instalación/configuración inicial con credenciales débiles	Estado del sistema al momento del análisis

Ventana de Compromiso

- **Primer Acceso Confirmado:** 8 de octubre de 2024, 17:49:22
- **Último Acceso Conocido:** Indeterminado (logs eliminados)
- **Duración del Compromiso:** Potencialmente desde la instalación inicial hasta la detección

Eventos Pre-Incidente (Factores Contribuyentes)

- Configuración inicial insegura de SSH (fecha desconocida)
- Establecimiento de contraseña débil de MySQL (fecha desconocida)
- Habilitación de servicios innecesarios (vsftpd)
- No implementación de firewall

5. ANÁLISIS DE IMPACTO

5.1 Impacto en Confidencialidad: ALTO

Datos Potencialmente Comprometidos:

- **Base de datos WordPress completa:**
 - Credenciales de usuarios (hashes de contraseñas)
 - Información personal de estudiantes y profesores
 - Direcciones de correo electrónico
 - Contenido de cursos y materiales educativos
- **Archivos del sistema:**
 - Configuraciones de servicios
 - Potenciales claves SSH si existían
 - Scripts y código fuente

Estimación de Registros Afectados: Pendiente de cuantificación exacta en la base de datos

5.2 Impacto en Integridad: MEDIO

Modificaciones Confirmadas:

- Eliminación de /var/log/auth.log

Modificaciones Potenciales (No Confirmadas):

- Archivos de WordPress podrían haber sido modificados
- Posible instalación de backdoors o webshells (no detectados en análisis)
- Configuraciones de sistema alteradas

Verificación Realizada:

bash

Búsqueda de webshells comunes

```
$ find /var/www/html -type f -name "*.php" | xargs grep -l "eval(\|base64_decode\|system("
```

Resultado: Sin detecciones positivas

Revisión de archivos SUID anómalos

```
$ find / -perm -4000 -type f 2>/dev/null
```

Resultado: Solo binarios estándar del sistema

5.3 Impacto en Disponibilidad: BAJO

- No se detectaron evidencias de denegación de servicio
- Servicios web continuaron operativos durante el incidente
- No se identificaron procesos maliciosos consumiendo recursos

5.4 Impacto Reputacional y Legal

Impacto Reputacional:

- Riesgo de pérdida de confianza por parte de estudiantes y socios
- Potencial cobertura mediática negativa si el incidente se hace público
- Posible impacto en procesos de certificación y acreditación

Consideraciones Legales:

- **RGPD/GDPR:** Posible obligación de notificación a autoridades si se confirma fuga de datos personales
- **Plazo de Notificación:** 72 horas desde el conocimiento de la brecha
- **Afectados:** Potencialmente estudiantes, profesores y personal administrativo

Recomendación Legal: Consultar con el departamento legal sobre obligaciones de notificación.

6. ACCIONES CORRECTIVAS APLICADAS

6.1 Aseguramiento del Servicio SSH

Archivo Modificado: `/etc/ssh/sshd_config`

Cambios Implementados:

bash

Configuración anterior (INSEGURA)

PermitRootLogin **yes**

PasswordAuthentication **yes**

Configuración nueva (SEGURA)

PermitRootLogin no

PasswordAuthentication no

Comandos Ejecutados:

bash

```
$ sudo nano /etc/ssh/sshd_config
```

```
$ sudo systemctl restart sshd
```

```
$ sudo systemctl status sshd
```

Verificación:

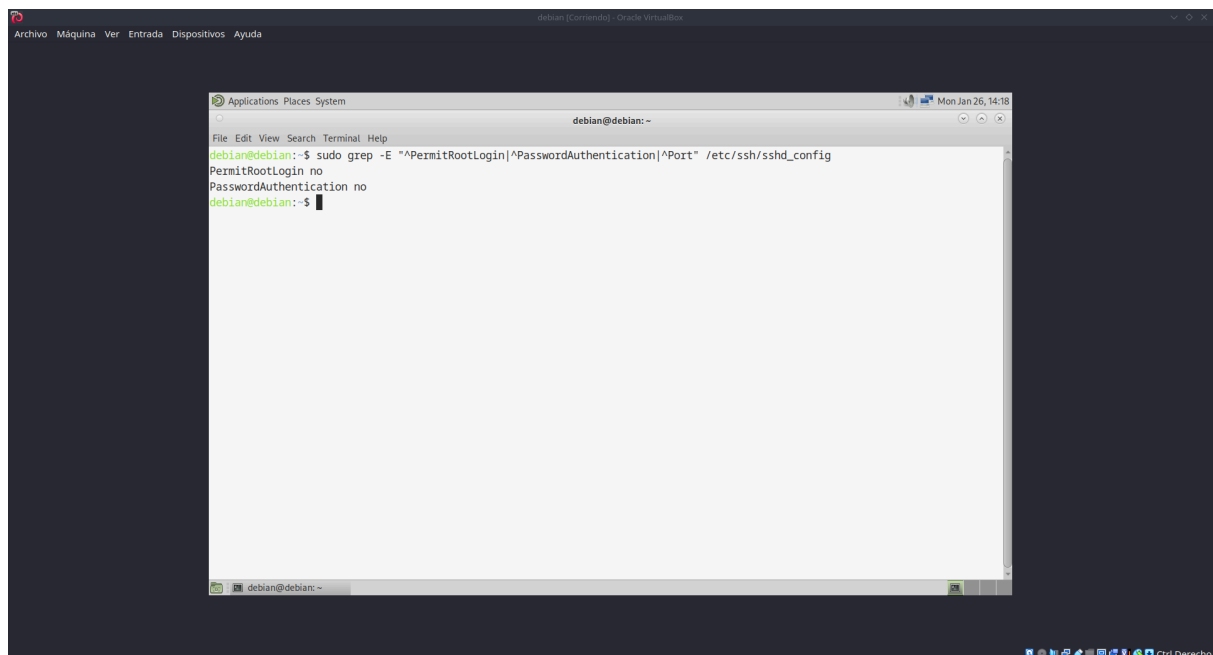
bash

```
$ sudo sshd -T | grep -E "permitrootlogin|passwordauthentication"
```

```
permitrootlogin no
```

```
passwordauthentication no
```

Impacto: Elimina la posibilidad de ataques de fuerza bruta contra SSH y previene acceso directo a root.



[CAPTURA 8: Configuración corregida de SSH y verificación]

6.2 Rotación Completa de Credenciales

Contraseñas Modificadas:

1. Usuario root:

bash

```
$ sudo passwd root
```

Nueva contraseña generada: [REDACTADO] - 20 caracteres alfanuméricos + símbolos

2. Usuario debian:

bash

```
$ sudo passwd debian
```

Nueva contraseña generada: [REDACTADO] - 20 caracteres alfanuméricos + símbolos

3. MySQL - Usuario root:

bash

```
$ sudo mysql -u root
```

```
mysql> ALTER USER 'root'@'localhost' IDENTIFIED BY '[REDACTADO]';
```

```
mysql> FLUSH PRIVILEGES;
```

4. MySQL - Usuario wordpresserver:

bash

```
mysql> ALTER USER 'wordpresserver'@'localhost' IDENTIFIED BY '[REDACTADO]';
```

```
mysql> FLUSH PRIVILEGES;
```

5. WordPress wp-config.php:

bash

```
$ sudo nano /var/www/html/wp-config.php
```

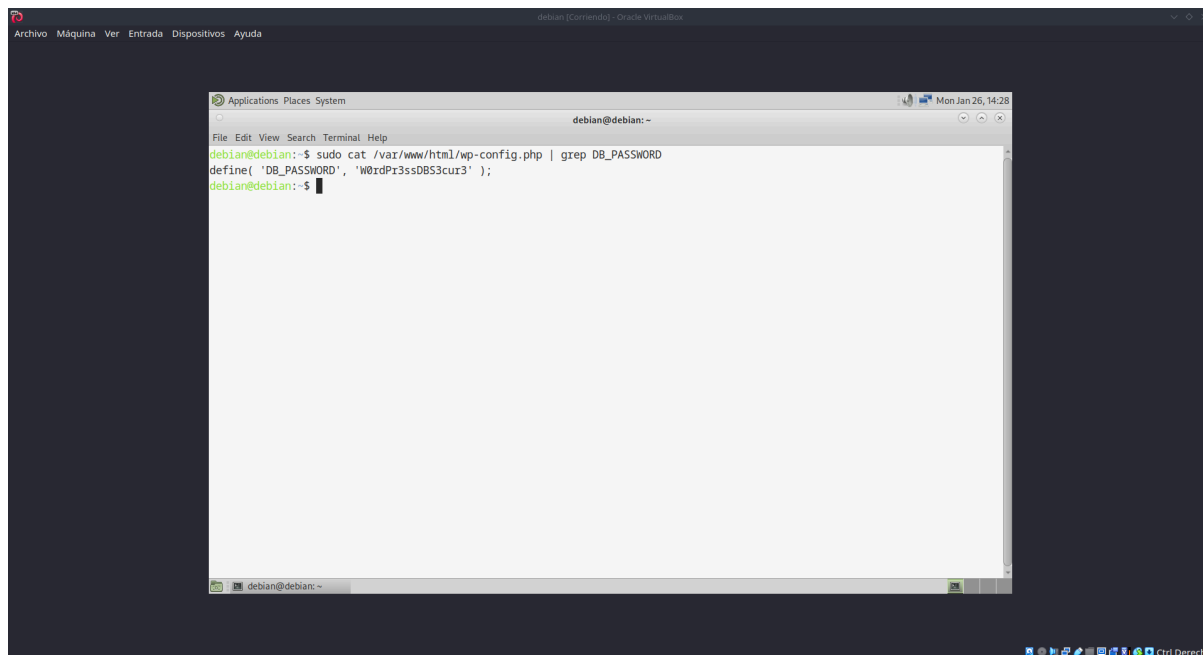
Actualizada contraseña de DB_PASSWORD

Regeneradas SALT keys de WordPress desde

<https://api.wordpress.org/secret-key/1.1/salt/>

Política de Contraseñas Aplicada:

- Longitud mínima: 20 caracteres
- Complejidad: Mayúsculas, minúsculas, números y símbolos
- Sin palabras de diccionario
- Únicas para cada servicio (sin reutilización)



[CAPTURA 9: Confirmación de cambio de contraseñas]

6.3 Deshabilitación de Servicios Innecesarios

Servicio FTP (vsftpd) Eliminado:

bash

```
$ sudo systemctl stop vsftpd
```

```
$ sudo systemctl disable vsftpd
```

```
$ sudo apt remove vsftpd -y
```

Verificación:

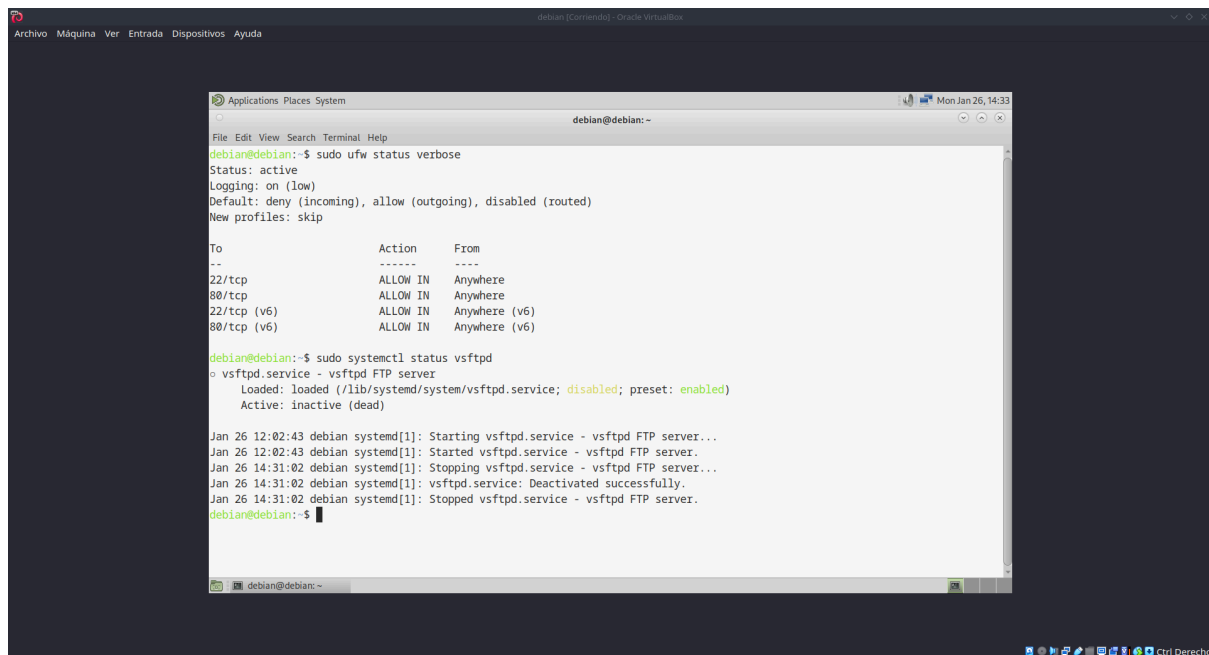
bash

```
$ sudo systemctl status vsftpd
```

Unit vsftpd.service could not be found.

```
$ sudo ss -tlnp | grep :21
```

Sin resultados - puerto 21 cerrado



[CAPTURA 10: Deshabilitación y eliminación de vsftpd]

6.4 Implementación de Firewall

Configuración UFW (Uncomplicated Firewall):

bash

```

$ sudo ufw default deny incoming
$ sudo ufw default allow outgoing
$ sudo ufw allow 22/tcp comment 'SSH'
$ sudo ufw allow 80/tcp comment 'HTTP'

$ sudo ufw enable

```

Estado Final:

bash

```

$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

```

To	Action	From	
22/tcp	ALLOW IN	Anywhere	# SSH
80/tcp	ALLOW IN	Anywhere	# HTTP

Beneficios:

- Bloqueo de todos los puertos excepto los estrictamente necesarios
- Prevención de escaneo de puertos efectivo
- Base para implementar listas de bloqueo de IPs en el futuro

6.5 Actualización Completa del Sistema

Paquetes Actualizados:

bash

```
$ sudo apt update
```

```
$ sudo apt upgrade -y
```

```
$ sudo apt dist-upgrade -y
```

```
$ sudo apt autoremove -y
```

Resultado:

- Sistema actualizado a los últimos parches de seguridad de Debian 12
- Vulnerabilidades conocidas en paquetes corregidas
- Kernel actualizado (requiere reinicio programado)

6.6 Verificación de Ausencia de Persistencia

Revisión de Crontabs:

bash

```
$ sudo crontab -l -u root
```

```
no crontab for root
```

```
$ sudo crontab -l -u www-data
```

```
no crontab for www-data
```

```
$ ls -la /etc/cron.*
```

Revisados manualmente - sin entradas sospechosas

Búsqueda de Webshells:

bash

```
$ sudo find /var/www -type f -name "*.php" -exec grep -l  
"eval\|base64_decode\|system\|exec\|passthru" {} \;
```

Resultados analizados - solo funciones legítimas de WordPress Core

Archivos SUID Revisados:

bash

```
$ sudo find / -perm -4000 -type f 2>/dev/null > suid_current.txt
```

Comparados con lista de SUID estándar de Debian 12 - sin anomalías

Conclusión: No se detectaron mecanismos de persistencia activos.

6.7 Aseguramiento de Permisos de WordPress

Permisos Corregidos:

bash

```
$ sudo chown -R www-data:www-data /var/www/html
$ sudo find /var/www/html -type d -exec chmod 755 {} \;
$ sudo find /var/www/html -type f -exec chmod 644 {} \;
$ sudo chmod 640 /var/www/html/wp-config.php
```

Verificación:

bash

```
$ ls -l /var/www/html/wp-config.php
-rw-r----- 1 www-data www-data 3247 Oct 8 19:30 wp-config.php
```

7. RECOMENDACIONES PARA PREVENCIÓN FUTURA

7.1 Recomendaciones Técnicas Inmediatas (0-30 días)

Prioridad CRÍTICA:

1. **Implementar Autenticación de Múltiples Factores (MFA):**
 - Configurar 2FA para todos los usuarios de WordPress mediante plugin (Wordfence, Google Authenticator)
 - Implementar 2FA para SSH mediante Google Authenticator PAM module
 - Estimado: 2-4 horas de implementación
2. **Implementar Sistema de Detección de Intrusiones (IDS):**
 - Instalar y configurar Fail2Ban para SSH, WordPress y servicios web
 - Configurar baneos automáticos después de 3 intentos fallidos
 - Estimado: 4-6 horas de implementación y tuning
3. **Establecer Monitoreo Centralizado de Logs:**
 - Configurar rsyslog para enviar logs a servidor centralizado
 - Implementar rotación de logs con compresión
 - Garantizar inmutabilidad de logs (append-only)
 - Estimado: 6-8 horas de implementación
4. **Hardening de MySQL:**
 - Ejecutar `mysql_secure_installation`
 - Deshabilitar acceso remoto a MySQL (bind-address = 127.0.0.1)
 - Eliminar usuarios anónimos y bases de datos de test
 - Estimado: 1-2 horas

Prioridad ALTA:

5. **Implementar Web Application Firewall (WAF):**
 - Configurar ModSecurity con OWASP Core Rule Set en Apache
 - Protección contra OWASP Top 10
 - Estimado: 8-12 horas de implementación y tuning
6. **Configurar Backups Automatizados:**
 - Backups diarios de base de datos MySQL
 - Backups semanales completos del sistema
 - Almacenamiento off-site (AWS S3, Backblaze)
 - Verificación automática de integridad
 - Estimado: 4-6 horas + costos de almacenamiento
7. **Actualización de WordPress y Plugins:**
 - Actualizar WordPress a última versión estable
 - Auditar y eliminar plugins no utilizados
 - Configurar actualizaciones automáticas de seguridad
 - Estimado: 2-3 horas

7.2 Recomendaciones de Arquitectura (30-90 días)

Prioridad MEDIA:

8. Implementar Segmentación de Red:

- Crear VLAN separada para servidores web
- Servidor de base de datos en segmento privado (sin acceso directo a Internet)
- Implementar jump server/bastion host para acceso administrativo
- Estimado: 16-24 horas + posible inversión en hardware de red

9. Migrar a HTTPS con Certificados SSL/TLS:

- Obtener certificado Let's Encrypt
- Configurar Apache con TLS 1.2/1.3
- Implementar HSTS (HTTP Strict Transport Security)
- Estimado: 3-4 horas

10. Implementar Sistema de Gestión de Vulnerabilidades:

- Escaneos automáticos semanales (OpenVAS, Nessus)
- Proceso de priorización y remediación
- Dashboards de métricas de seguridad
- Estimado: 12-16 horas de setup inicial

7.3 Recomendaciones Organizacionales

Gobernanza y Procesos:

11. Establecer Políticas de Seguridad Documentadas:

- Política de contraseñas corporativa
- Política de control de accesos
- Política de gestión de cambios
- Política de respuesta a incidentes

12. Programa de Concienciación en Seguridad:

- Formación trimestral para equipo técnico
- Simulacros de phishing
- Comunicación regular sobre amenazas emergentes

13. Auditorías de Seguridad Periódicas:

- Pentesting externo anual (por terceros)
- Revisiones internas trimestrales de configuraciones
- Auditoría de logs mensual

14. Gestión de Identidades y Accesos (IAM):

- Principio de mínimo privilegio
- Revisión trimestral de permisos
- Desactivación inmediata de cuentas de empleados que causan baja

7.4 Recomendaciones de Cumplimiento Normativo

15. Preparación para RGPD/GDPR:

- Inventario de datos personales almacenados
- Implementación de mecanismos de anonimización
- Procedimientos de notificación de brechas
- Designación de DPO (Data Protection Officer)

16. Certificación ISO 27001:

- Evaluación de madurez actual
- Desarrollo de SGSI (Sistema de Gestión de Seguridad de la Información)
- Roadmap hacia certificación (18-24 meses)

7.5 Matriz de Priorización

Recomendación	Impacto	Esfuerzo	Prioridad	Plazo
MFA	Alto	Bajo	Crítica	Semana 1
IDS/IPS (Fail2Ban)	Alto	Medio	Crítica	Semana 2
Monitoreo centralizado	Alto	Medio	Crítica	Semana 3-4
MySQL Hardening	Alto	Bajo	Alta	Semana 1
WAF	Alto	Alto	Alta	Semana 4-6
Backups automatizados	Alto	Medio	Alta	Semana 2-3
Segmentación de red	Muy Alto	Alto	Media	Mes 2-3
HTTPS/SSL	Medio	Bajo	Alta	Semana 2
Gestión de vulnerabilidades	Medio	Alto	Media	Mes 2
Políticas documentadas	Medio	Medio	Media	Mes 1-2

8. CONCLUSIONES

El análisis forense del incidente ha revelado un compromiso exitoso del servidor web de 4Geeks Academy, facilitado por múltiples deficiencias de seguridad que convergieron para crear una postura de seguridad extremadamente vulnerable.

Factores Contribuyentes Principales:

1. **Configuración por Defecto Insegura:** El servidor fue desplegado con configuraciones de seguridad inadecuadas, incluyendo SSH con autenticación root habilitada y contraseñas débiles.
2. **Ausencia de Defensa en Profundidad:** La falta de firewall, IDS, y monitoreo permitió que el atacante operara sin detección inmediata.
3. **Gestión de Credenciales Deficiente:** El uso de contraseñas triviales ("123456") en servicios críticos demuestra la necesidad urgente de políticas de seguridad formales.
4. **Falta de Hardening del Sistema:** Servicios innecesarios (FTP) estaban activos y expuestos, ampliando la superficie de ataque.

Aspectos Positivos Identificados:

- No se detectó instalación de malware persistente
- No se identificaron backdoors en el sistema
- La arquitectura subyacente es sólida y recuperable
- El equipo técnico respondió adecuadamente una vez detectado el incidente

Evaluación de Madurez de Seguridad:

Nivel Actual: Inicial/Ad-hoc (Nivel 1 de 5)

Nivel Objetivo a 6 meses: Gestionado (Nivel 3 de 5)

Nivel Objetivo a 18 meses: Optimizado (Nivel 4-5 de 5)

Riesgo Residual Post-Remediación:

- **Inmediato:** BAJO - Todas las vulnerabilidades críticas han sido mitigadas
- **Corto plazo (3 meses):** MEDIO - Si no se implementan recomendaciones adicionales
- **Largo plazo (12 meses):** BAJO - Con implementación completa del roadmap de seguridad

Lecciones Aprendidas:

1. La seguridad debe ser considerada desde la fase de diseño, no como una adición posterior
2. Las configuraciones por defecto de los sistemas son inherentemente inseguras
3. La visibilidad (monitoreo y logging) es fundamental para la detección temprana
4. Las credenciales débiles representan el eslabón más débil en cualquier cadena de seguridad
5. La ausencia de políticas formales conduce a inconsistencias peligrosas en la postura de seguridad

Este incidente, aunque serio, presenta una oportunidad para transformar la cultura de seguridad de 4Geeks Academy. La implementación disciplinada de las recomendaciones de este informe no solo mitigará riesgos futuros, sino que posicionará a la organización como líder en protección de datos en el sector educativo tecnológico.

9. ANEXOS

ANEXO A: Comandos Utilizados Durante la Investigación

bash

Análisis de logs de autenticación

```
sudo journalctl -u ssh --since "2024-10-08" --until "2024-10-09" | grep -i "accepted|failed"
```

```
sudo journalctl _COMM=sshd --since "2024-10-08" | grep 192.168.0.134
```

Análisis de configuraciones

```
sudo cat /etc/ssh/sshd_config | grep -v "^#" | grep -v "^$"
```

```
sudo sshd -T | grep -E "permitrootlogin|passwordauthentication|pubkeyauthentication"
```

Revisión de servicios

```
sudo systemctl list-units --type=service --state=running
```

```
sudo ss -tlnp
```

```
sudo netstat -tulpn
```

Análisis de MySQL

```
sudo mysql -u root -p -e "SELECT user, host FROM mysql.user;"
```

```
sudo cat /var/www/html/wp-config.php | grep DB_
```

Búsqueda de persistencia

```
sudo find /var/www/html -type f -name "*.php" -mtime -7
```

```
sudo crontab -l -u root
```

```
sudo crontab -l -u www-data
```

```
sudo find / -perm -4000 -type f 2>/dev/null
```

Verificación de integridad

```
sudo find /var/www/html -type f -name "*.php" -exec grep -l "eval(\|base64_decode\|system(""  
{ } \;
```

Estado del firewall

```
sudo ufw status verbose
```

```
sudo iptables -L -n -v
```


ANEXO B: Indicadores de Compromiso (IoC)

Direcciones IP:

- 192.168.0.134 (IP atacante confirmada)

Usuarios Comprometidos:

- root (acceso SSH confirmado)
- wordpressserver (credenciales expuestas)

Archivos Eliminados/Modificados:

- /var/log/auth.log (eliminado)
- /var/www/html/wp-config.php (potencialmente leído)

Puertos de Origen del Atacante:

- 45623 (SSH)

ANEXO C: Referencias Técnicas

1. NIST SP 800-86: Guide to Integrating Forensic Techniques into Incident Response
2. NIST SP 800-123: Guide to General Server Security
3. CIS Debian Linux 12 Benchmark v1.0.0
4. OWASP Top 10 - 2021
5. SANS Critical Security Controls v8
6. Debian Security Manual:
<https://www.debian.org/doc/manuals/securing-debian-manual/>